Table of Contents

1. Executive Summary 3
2. Project Overview 4
2.1 Background and Motivation 4
2.2 Problem Statement 5
2.3 Project Objectives 5
3. Scope and Boundaries 6
4. System Architecture 7
4.1 High-Level Architecture 7
4.2 Component Descriptions 8
4.3 Data Flow Diagram 9
5. Encryption Design 9
5.1 Cryptographic Standards 9
5.2 Key Management 10
5.3 Deleted File Recovery Prevention 11
6. Technology Stack 12
7. Functional Requirements 13
8. Non-Functional Requirements 14
9. Implementation Phases 15
10. Security Analysis 16
10.1 Threat Modelling (STRIDE) 16
10.2 Risk Register 17
10.3 Penetration Testing Summary 18
11. Testing and Quality Assurance 19
12. Performance Benchmarks 20
13. Compliance and Regulatory Alignment 21
14. Deployment and Operations 22
15. Budget and Resource Summary 23
16. Lessons Learned and Recommendations 24
17. Conclusion 25

1. Executive Summary

The Deleted File Encryption Tool (DFET) for Cloud Storage is a purpose-built cybersecurity solution designed to ensure that files deleted from cloud storage environments are rendered permanently irrecoverable by applying cryptographic erasure techniques at the moment of deletion. This project was commissioned by SecureVault Technologies Inc. in response to growing regulatory obligations under GDPR, CCPA, HIPAA, and SOC 2 Type II, as well as escalating enterprise demand for data lifecycle security.

Cloud storage platforms—including AWS S3, Microsoft Azure Blob Storage, and Google Cloud Storage—do not guarantee cryptographic destruction of deleted objects. Residual data blocks may persist on underlying storage media, making forensic recovery possible. The DFET addresses this gap by encrypting all files at upload using per-file asymmetric keys, and by securely destroying the decryption key at the moment of deletion. This approach ensures that even if raw storage sectors are later recovered, the data is indecipherable.

Key Outcomes
The project was delivered on schedule across four development sprints. The system supports encryption at rest (AES-256-GCM), secure key destruction via Hardware Security Module (HSM), real-time audit logging, and integration with all major cloud object storage APIs. Independent penetration testing confirmed zero critical vulnerabilities.

Files Secured (Pilot)	Avg Deletion Latency	Compliance Score	Pen-Test CVEs
2.4 Million	**< 95 ms**	**98.6 / 100**	**0 Critical**

2. Project Overview

2.1 Background and Motivation

Modern enterprises routinely store sensitive data—intellectual property, personally identifiable information (PII), financial records, and health information—in cloud environments. While cloud providers implement strong access controls and at-rest encryption at the volume level, the deletion of individual objects does not automatically translate to cryptographic destruction. In many deployments, deleted files remain on cold-tier storage or backup snapshots for weeks or months.

High-profile data breaches involving recovered 'deleted' files have demonstrated the real-world consequences of this gap. Regulatory frameworks have responded by requiring organisations to implement data erasure controls that go beyond simple logical deletion. The DFET project was initiated to close this gap across cloud storage environments, providing a technically sound, auditable, and standards-compliant solution.

Internal audits conducted in Q1 2024 revealed that 34% of enterprise data classified as 'deleted' could be partially recovered from cloud provider snapshots. This finding, combined with a €2.1 million regulatory fine imposed on a peer organisation for inadequate data erasure practices, justified an urgent investment in robust cryptographic deletion capabilities.

2.2 Problem Statement

> **Core Problem**
> Cloud storage providers do not guarantee cryptographic destruction of deleted data. Logical deletion removes object metadata but may leave encrypted or unencrypted data blocks on physical media, accessible to forensic recovery, rogue insiders, or compromised cloud administrator accounts.

The absence of file-level cryptographic erasure creates several distinct risks: (i) forensic recovery by external adversaries who obtain access to decommissioned storage hardware; (ii) insider threats from cloud provider employees with direct media access; (iii) regulatory non-compliance under data minimisation and right-to-erasure obligations; and (iv) legal liability arising from the continued existence of data that was purported to have been deleted.

2.3 Project Objectives

The project was scoped to deliver the following primary objectives:

- Design and implement a file-level encryption layer that wraps all cloud storage write operations, generating unique per-file encryption keys.
- Integrate a Hardware Security Module (HSM)-backed key management service that supports atomic key destruction upon file deletion.
- Achieve compatibility with AWS S3, Azure Blob Storage, and Google Cloud Storage via a unified API abstraction layer.
- Ensure deletion operations complete within 100 milliseconds of client request for files up to 1 GB, maintaining end-user service quality.

- Produce a full audit trail of all encryption, access, and deletion events, exportable in SIEM-compatible formats.
- Achieve compliance certification readiness for GDPR Article 17, CCPA Section 1798.105, HIPAA 45 CFR 164.310(d)(2)(i), and SOC 2 CC6.5.

3. Scope and Boundaries

3.1 In Scope

The following systems, components, and capabilities are within the defined scope of this project:

- File upload interception and AES-256-GCM encryption for AWS S3, Azure Blob Storage, and Google Cloud Storage.
- Per-file asymmetric key generation (RSA-4096) and storage within a FIPS 140-2 Level 3 certified HSM cluster.
- Atomic key destruction workflow triggered by DELETE API calls, ensuring no key copy persists after acknowledged deletion.
- Transparent proxy mode for legacy applications that interact with cloud storage SDKs without modification.
- Administrative dashboard for key inventory management, audit log review, and compliance reporting.
- REST API for programmatic integration with enterprise ITSM, DLP, and SIEM platforms.
- Support for files ranging in size from 1 KB to 5 TB using multipart encryption strategies.
- Deployment on Kubernetes (EKS, AKS, GKE) with Helm chart packaging.

3.2 Out of Scope

The following items are explicitly excluded from this project's scope:

- Encryption of database records, structured data stores, or block storage volumes (covered by separate initiatives).
- Client-side encryption performed within end-user device applications (future roadmap item).
- Recovery or migration of historically deleted files that pre-date DFET deployment.
- Integration with on-premises storage systems (NAS, SAN) in this release.
- Backup encryption beyond the scope of the three supported cloud providers.

3.3 Assumptions and Constraints

Assumption	Constraint
Cloud provider APIs remain stable and backward-compatible during project duration.	HSM provisioning lead time of 6 weeks must be factored into sprint planning.
Client organisations have network access to cloud regions with latency under 30 ms.	System must not increase storage costs by more than 3% due to metadata overhead.
TLS 1.3 is enforced on all communication channels between DFET components.	Encryption operations must not block the calling thread for longer than 10 ms per KB.

4. System Architecture

4.1 High-Level Architecture

The DFET solution adopts a proxy-intercept architecture pattern. All client storage operations—uploads, downloads, and deletions—are routed through the DFET Gateway Service, which applies encryption or decryption transparently and interfaces with the Key Management Service (KMS) component backed by the HSM cluster. The Gateway Service presents a standards-compliant S3-compatible API to upstream clients, abstracting provider-specific protocol differences.

The architecture is horizontally scalable, stateless at the Gateway tier, and resilient to individual node failures through active-active clustering. State is maintained exclusively within the HSM Key Store and the Audit Logging Service, both of which leverage high-availability persistence layers.

Tier	Component	Responsibility
Client Tier	SDK / Proxy Agent	Intercepts storage API calls from applications without code changes.
Gateway Tier	DFET Gateway Service	Applies encryption/decryption, routes to cloud providers, calls KMS.
Key Management	HSM Key Manager	Generates, stores, and destroys per-file AES & RSA keys.
Cloud Providers	AWS S3 / Azure Blob / GCS	Stores exclusively encrypted ciphertext blobs.
Audit & Compliance	Audit Logging Service	Immutable event store; exports to Splunk, Sentinel, Chronicle.
Administration	Admin Console (React)	Dashboard for operations, compliance reports, key inventory.

4.2 Component Descriptions

4.2.1 DFET Gateway Service

The Gateway Service is a polyglot microservice implemented in Go 1.22, chosen for its high throughput, low memory footprint, and native concurrency primitives. It exposes an S3-compatible HTTP/2 API and implements provider-specific adapters for Azure Blob and GCS using pluggable transport modules. Encryption is performed using Go's crypto/aes standard library with hardware acceleration via AES-NI CPU instructions, achieving throughputs exceeding 12 GB/s on modern hardware.

4.2.2 HSM Key Manager

The Key Manager is a Java 21 service deployed as a sidecar to the Gateway, communicating over a local Unix socket for minimal latency. It interfaces with Thales Luna Network HSM 7 appliances via the PKCS#11 API. Per-file AES-256 data encryption keys (DEKs) are generated within the HSM boundary and wrapped with a tenant-specific RSA-4096 key encryption key (KEK) before storage. At

deletion, the DEK is destroyed within the HSM hardware and the metadata record is updated to mark the key as permanently purged.

4.2.3 Audit Logging Service

All operations generate structured JSON events published to an Apache Kafka topic. The Audit Logging Service consumes these events and writes them to an append-only TimescaleDB instance. Events are cryptographically chained using SHA-3-256 hashes, making post-hoc tampering detectable. Audit logs are exportable to SIEM platforms and are retained for a configurable period (default: 7 years) to satisfy regulatory requirements.

4.3 Data Flow — File Upload

When a client application initiates a PUT/upload operation: (1) The DFET Proxy Agent intercepts the SDK call and forwards it to the Gateway Service over mTLS. (2) The Gateway requests a new DEK from the KMS; the HSM generates the key internally and returns the wrapped DEK. (3) The Gateway streams the plaintext file through an AES-256-GCM cipher, encrypting each chunk inline. (4) The ciphertext is forwarded to the target cloud provider bucket. (5) An encrypted metadata record associating the file identifier with the wrapped DEK is persisted. (6) An audit event is emitted recording the upload, encryption algorithm, key ID, and requesting identity.

5. Encryption Design

5.1 Cryptographic Standards

All cryptographic primitives employed by DFET have been selected in accordance with NIST SP 800-175B Rev. 1 (Guideline for Using Cryptographic Standards in the Federal Government) and NSA Suite B requirements. The following table details the algorithms, key sizes, and modes in use:

Purpose	Algorithm	Key/Tag Size	Standard
Data Encryption (DEK)	AES-GCM	256-bit / 128-bit tag	NIST FIPS 197, SP 800-38D
Key Encryption (KEK)	RSA-OAEP	4096-bit	NIST SP 800-56B Rev. 2
Key Derivation	HKDF-SHA-256	256-bit output	RFC 5869, NIST SP 800-56C
Digital Signatures	ECDSA P-384	384-bit	NIST FIPS 186-5
Hashing (Audit Chain)	SHA3-256	256-bit	NIST FIPS 202
TLS Transport	TLS 1.3 / AES-256-GCM	256-bit session	RFC 8446
Random Generation	DRBG (CTR-mode)	256-bit seed	NIST SP 800-90A Rev. 1

5.2 Key Management

DFET implements a three-tier key hierarchy: (1) Master Key — a hardware-bound 256-bit AES key generated and permanently resident within the HSM. It never leaves the hardware boundary in plaintext form. (2) Key Encryption Keys (KEKs) — tenant-specific RSA-4096 key pairs used to wrap DEKs for storage. KEKs are rotated on a configurable schedule (default: 90 days). (3) Data Encryption Keys (DEKs) — unique AES-256 keys generated per file at upload time. The wrapped DEK is stored alongside encrypted file metadata.

Key rotation for KEKs triggers a re-wrapping workflow: all active DEKs are unwrapped under the old KEK and immediately re-wrapped under the new KEK within the HSM boundary. No plaintext key material is ever present outside HSM memory. This process is performed asynchronously with zero downtime using a dual-key acceptance window of 15 minutes.

> **HSM Certification**
> The Thales Luna Network HSM 7 appliances used in this deployment hold FIPS 140-2 Level 3 certification and CC EAL4+ evaluation. Physical tamper response mechanisms zeroize key material upon intrusion detection.

5.3 Deleted File Recovery Prevention

The core innovation of DFET is its cryptographic erasure mechanism. When a file deletion request is received, the system executes the following atomic sequence within a distributed transaction: (1) Locate the DEK record associated with the file identifier. (2) Instruct the HSM to destroy the DEK —

all copies, including backup HSM nodes, via synchronised deletion. (3) Confirm DEK destruction acknowledgement from all HSM cluster nodes. (4) Issue the DELETE command to the cloud storage provider. (5) Update the metadata store to record permanent deletion. (6) Emit a deletion audit event with key destruction confirmation hash.

Because the ciphertext of a file encrypted with AES-256-GCM is computationally indistinguishable from random noise without the corresponding key, destruction of the DEK renders the stored ciphertext permanently irrecoverable. This approach satisfies 'crypto-shredding' requirements as defined in NIST SP 800-88 Rev. 1 (Guidelines for Media Sanitisation) for cloud-hosted data.

6. Technology Stack

The technology selection process prioritised security, performance, operational maturity, and vendor neutrality. All selected components have active upstream maintenance, published CVE response SLAs, and documented security hardening guides.

Category	Technology	Version	Rationale
Gateway Service	Go	1.22	High throughput, AES-NI acceleration, low memory.
Key Manager	Java (Spring Boot)	21 / 3.2	PKCS#11 library maturity, HSM vendor support.
Admin Console	React + TypeScript	18 / 5.4	Ecosystem maturity, type safety, accessibility.
Container Orchestration	Kubernetes	1.30	Industry standard, strong RBAC, network policies.
Service Mesh	Istio	1.22	mTLS enforcement, traffic observability.
Message Bus	Apache Kafka	3.7	High-durability audit event streaming.
Audit Database	TimescaleDB (PostgreSQL)	2.15	Time-series optimised, append-only partitions.
Secrets Management	HashiCorp Vault	1.17	Dynamic secrets, HSM seal integration.
HSM	Thales Luna Network HSM 7	7.8	FIPS 140-2 Level 3, PKCS#11.
CI/CD	GitHub Actions + ArgoCD	—	GitOps, policy-as-code enforcement.
Observability	Prometheus + Grafana	2.53 / 11.1	SLO dashboards, alerting.
SIEM Integration	OpenTelemetry Collector	0.102	Vendor-neutral log/trace export.

7. Functional Requirements

The functional requirements were elicited through stakeholder workshops involving security engineering, legal and compliance, platform operations, and enterprise client representatives. Requirements are classified using MoSCoW prioritisation.

ID	Requirement	Priority	Status
FR-01	System shall encrypt all files at upload using AES-256-GCM with a unique per-file DEK.	**Must Have**	**Done**
FR-02	System shall destroy the DEK atomically upon receipt of a file deletion request.	**Must Have**	**Done**
FR-03	DEK destruction shall be confirmed by all HSM nodes before DELETE is issued to the cloud provider.	**Must Have**	**Done**
FR-04	System shall support AWS S3, Azure Blob Storage, and Google Cloud Storage.	**Must Have**	**Done**
FR-05	Proxy Agent shall intercept storage SDK calls transparently, requiring zero application code changes.	**Must Have**	**Done**
FR-06	System shall generate a tamper-evident audit event for every encryption, decryption, and deletion operation.	**Must Have**	**Done**
FR-07	Audit logs shall be exportable to Splunk, Microsoft Sentinel, and Google Chronicle.	**Should Have**	**Done**
FR-08	System shall support multi-tenancy with cryptographic isolation between tenant key spaces.	**Must Have**	**Done**
FR-09	KEK rotation shall be performed with zero service downtime using a dual-key acceptance window.	**Should Have**	**Done**
FR-10	Admin Console shall display real-time key inventory, deletion events, and compliance status.	**Should Have**	**Done**
FR-11	System shall support files up to 5 TB using streaming multipart encryption.	**Must Have**	**Done**
FR-12	System shall expose a REST API for integration with ITSM and DLP platforms.	**Should Have**	**Done**
FR-13	Compliance reports (GDPR, HIPAA, SOC 2) shall be generatable on demand.	**Should Have**	**Done**
FR-14	System shall alert on failed DEK destructions within 60 seconds via PagerDuty/OpsGenie.	**Must Have**	**Done**
FR-15	System shall support bring-your-own-key (BYOK) for enterprise tenants.	**Could Have**	**Done**

8. Non-Functional Requirements

Category	Requirement	Target / Achieved
Performance	End-to-end deletion latency (file ≤ 1 GB)	< 100 ms | Achieved: 92 ms avg
Performance	Encryption throughput (per gateway node)	> 2 GB/s | Achieved: 3.1 GB/s
Availability	Gateway Service uptime SLA	99.95% | Pilot: 99.97%
Availability	HSM cluster recovery time objective (RTO)	< 30 s | Achieved: 18 s
Scalability	Concurrent encryption operations per node	10,000+ | Achieved: 14,200
Security	Cryptographic algorithm compliance	NIST FIPS 197 / 140-2 | Certified
Security	Network communication encryption	TLS 1.3 only | Enforced
Compliance	Audit log retention	7 years | Configurable
Compliance	GDPR Article 17 right-to-erasure satisfaction	Full | Legal verified
Maintainability	Mean time to patch critical CVE	< 24 hours | Process defined
Usability	Admin console page load (p95)	< 2 s | Achieved: 1.1 s
Portability	Supported Kubernetes distributions	EKS, AKS, GKE | All verified

9. Implementation Phases

The project was executed across four two-week sprints following a modified Scrum framework with security-gate reviews at the end of each sprint. An additional four-week pilot phase followed the development sprints.

Phase	Duration	Deliverables	Status	Owner
Phase 0	Weeks 1–2	Architecture design, threat modelling, HSM procurement, vendor selection, environment provisioning.	**Complete**	Arch
Phase 1	Weeks 3–4	Gateway Service core (Go), S3 adapter, AES-256-GCM encryption pipeline, unit tests (>90% coverage).	**Complete**	Eng
Phase 2	Weeks 5–6	HSM Key Manager (PKCS#11), Azure Blob and GCS adapters, DEK destruction workflow, integration tests.	**Complete**	Eng
Phase 3	Weeks 7–8	Audit Logging Service, Kafka pipeline, TimescaleDB schema, SIEM connectors, Admin Console MVP.	**Complete**	Eng
Phase 4	Weeks 9–10	Multi-tenancy, BYOK support, Compliance report generator, performance hardening, security pen-test.	**Complete**	Sec
Pilot	Weeks 11–14	Deployment to 3 enterprise pilot clients, 2.4 M files processed, SLA monitoring, issue resolution.	**Complete**	Ops

Each sprint concluded with a security gate review requiring sign-off from the CISO-appointed security architect. Gate criteria included static analysis (Semgrep, CodeQL), dependency vulnerability scanning (Trivy), and architecture drift review against the approved threat model. All gates were passed without deferral.

10. Security Analysis

10.1 Threat Modelling — STRIDE

A comprehensive STRIDE threat model was conducted during Phase 0 using Microsoft Threat Modelling Tool. The following table summarises identified threats and mitigations for the highest-priority attack surfaces:

STRIDE	Threat	Description	Mitigation	Risk
Spoofing	Identity Impersonation	Adversary impersonates a legitimate tenant to trigger DEK operations.	mTLS + OIDC identity federation; short-lived tokens.	**Low**
Tampering	Audit Log Manipulation	Insider modifies audit events to conceal unauthorised access.	Cryptographic event chaining (SHA-3); append-only DB.	**Low**
Repudiation	Deletion Denial	User claims file was not deleted; organisation cannot prove erasure.	Signed deletion receipts with key destruction hash.	**Low**
Info Disclosure	Ciphertext Side-Channel	Traffic analysis reveals file size or access patterns.	Padding to fixed block sizes; randomised access timing.	**Medium**
Denial of Service	HSM Overload	Attacker floods deletion API to exhaust HSM operation quota.	Rate limiting per tenant; HSM operation queuing.	**Medium**
Elevation of Priv	Container Escape	Compromised Gateway pod escalates to host or HSM network.	Seccomp/AppArmor profiles; network policy isolation.	**Low**

10.2 Risk Register

The project risk register tracks technical, operational, and compliance risks. The following table presents the top risks identified, with residual risk assessed post-mitigation:

ID	Risk Description	Likelihood	Impact	Mitigation
R-01	HSM hardware failure causing key unavailability.	Low	**Critical**	Active-active HSM cluster; automated failover < 30 s.
R-02	Cloud provider API change breaks adapter compatibility.	Medium	**High**	Versioned adapter interfaces; automated regression test suite.
R-03	DEK destruction partial failure (only some HSM nodes).	Low	**Critical**	Two-phase commit protocol; transaction rollback on partial failure.
R-04	Regulatory interpretation of crypto-shredding challenged.	Low	**High**	External legal opinion obtained; NIST SP 800-88 citation.

R-05	Performance degradation under peak load exceeds SLA.	Medium	**Medium**	Auto-scaling Gateway tier; load testing validated to 5x expected peak.
R-06	Insider threat: admin with HSM access extracts key material.	Low	**Critical**	Dual-control for HSM admin operations; hardware audit logs.

10.3 Penetration Testing Summary

An independent penetration test was conducted by NCC Group over a two-week engagement in March 2025. Testing covered the external attack surface, internal network segmentation, application logic, cryptographic implementation review, and HSM integration. The following summary reflects findings prior to remediation:

Critical	High	Medium	Low / Info
0	**1**	**3**	**7**

The sole High finding related to an overly permissive CORS policy on the Admin Console REST API, which was remediated within 48 hours of reporting. All medium and low findings were addressed prior to the pilot deployment. A re-test letter confirming full remediation was issued on 2025-03-28. The final penetration test report is maintained as a controlled document in the project artefact repository.

11. Testing and Quality Assurance

11.1 Test Strategy

A comprehensive multi-layered testing strategy was employed across all development phases. The testing pyramid was strictly followed: a broad base of unit tests, a middle layer of integration tests, and a smaller suite of end-to-end tests reflecting real cloud provider interactions.

Test Type	Tools	Coverage	Scope
Unit Tests	Go test, JUnit 5	94% line coverage	Individual functions, cipher modes, key operations, adapters.
Integration Tests	Testcontainers, LocalStack	87% component paths	Gateway-KMS interactions, Kafka pipeline, PKCS#11 HSM simulator.
End-to-End Tests	Playwright, K6	All FR scenarios	Full upload-download-delete cycles against live cloud sandboxes.
Performance Tests	K6, Gatling	SLA validated	Throughput, latency, concurrent connections, auto-scaling triggers.
Security Tests	Semgrep, Trivy, OWASP ZAP	CI/CD enforced	SAST, dependency CVEs, DAST against Admin Console.
Chaos Engineering	Chaos Mesh	Fault scenarios	HSM failover, Gateway node loss, Kafka partition failure.
Penetration Test	NCC Group (external)	Full attack surface	Application, network, cryptographic review, social engineering.

All tests are executed in the CI/CD pipeline on every pull request. Merge to the main branch requires: unit test passage, integration test passage, zero new critical or high SAST findings, and dependency scan with no known exploitable CVEs. The test suite executes in under 12 minutes using parallelised container-based runners.

12. Performance Benchmarks

Performance benchmarking was conducted against three hardware tiers: development (2 vCPU / 4 GB RAM), production-baseline (8 vCPU / 16 GB RAM), and production-high (16 vCPU / 32 GB RAM). All benchmarks represent median values at sustained 70% CPU utilisation over a 30-minute test window.

Metric	Dev Tier	Prod Baseline	Prod High
Encryption Throughput (MB/s)	820	3,100	5,800
Decryption Throughput (MB/s)	890	3,350	6,100
DEK Generation (ops/s)	1,200	4,800	9,200
DEK Destruction Latency (ms, p50)	42	22	14
DEK Destruction Latency (ms, p99)	118	67	41
Upload End-to-End Latency (ms)	145	78	52
Deletion End-to-End Latency (ms)	168	92	61
Concurrent Operations (per node)	3,200	14,200	26,500
Audit Event Ingest (events/s)	5,000	22,000	45,000

Performance Insight

The production-baseline configuration exceeds all SLA targets with significant headroom. AES-NI hardware acceleration is the primary contributor to high encryption throughput. HSM network round-trip time dominates DEK destruction latency; deploying the HSM in the same datacenter rack as the Gateway reduces p99 latency by 38%.

13. Compliance and Regulatory Alignment

DFET was designed from inception to satisfy data protection regulatory requirements across multiple jurisdictions. The following table maps DFET capabilities to specific regulatory provisions:

Regulation	Provision	How DFET Satisfies	Evidence
GDPR (EU) 2016/679	Art. 17 — Right to Erasure	Cryptographic erasure via DEK destruction renders data permanently irrecoverable within 100 ms.	Deletion receipts + audit log
CCPA (California)	§1798.105 — Right to Delete	Cryptographic shredding satisfies deletion obligation for cloud-stored personal information.	Legal opinion, audit trail
HIPAA 45 CFR	§164.310(d)(2)(i) — Disposal	Electronic PHI rendered irrecoverable using NIST SP 800-88 compliant crypto-shredding.	NIST alignment report
SOC 2 Type II	CC6.5 — Data Disposal	Key destruction and audit evidence satisfy CC6.5 disposal controls.	SOC 2 auditor letter
PCI DSS v4.0	Req. 9.4.7 — Media Destruction	Cryptographic erasure accepted as equivalently secure to physical media destruction.	QSA assessment
ISO 27001:2022	A.8.10 — Information Deletion	Documented key destruction process with cryptographic verification satisfies A.8.10.	ISMS procedure doc
NIST SP 800-88	Purge standard	DEK destruction within FIPS 140-2 L3 HSM satisfies Purge classification for cloud media.	Implementation guide

External legal counsel from Morrison Foerster LLP reviewed the cryptographic erasure implementation against GDPR Article 17 and issued a written legal opinion confirming that DEK destruction within a FIPS 140-2 Level 3 HSM satisfies the right-to-erasure obligation under the regulation. This opinion is maintained in the legal artefact repository.

14. Deployment and Operations

14.1 Deployment Architecture

DFET is packaged as a Helm chart (v3) supporting deployment to any CNCF-conformant Kubernetes distribution. The reference deployment topology consists of a minimum of three Gateway Service replicas behind an Ingress controller, two HSM Key Manager pods (one per HSM appliance), a Kafka cluster with three brokers, and a TimescaleDB instance with a hot standby replica.

Infrastructure-as-code is maintained in Terraform with separate modules for AWS, Azure, and GCP deployment. GitOps is implemented via ArgoCD, with all configuration changes requiring peer review and signed commits. Secrets are managed exclusively through HashiCorp Vault with dynamic short-lived credentials; no long-lived secrets are stored in Kubernetes secrets objects.

14.2 Operational Runbooks

The following operational procedures are documented in the DFET Operations Manual (v1.0):

- Gateway Service scale-out — triggered automatically by HPA at >70% CPU; manual override documented.
- HSM failover — automated within 30 seconds; operator verification steps and post-failover health check procedure.
- DEK destruction failure remediation — step-by-step guide for investigating and resolving partial destruction events.
- Kafka partition lag remediation — consumer group rebalancing and lag-alert response procedure.
- KEK rotation — pre-rotation checklist, execution steps, post-rotation verification, and rollback procedure.
- Compliance report generation — on-demand report procedure for GDPR, HIPAA, and SOC 2 audit requests.
- Security incident response — integration with corporate IR playbook; DFET-specific containment and evidence-preservation steps.

14.3 Monitoring and Alerting

Operational visibility is provided through a Prometheus/Grafana stack. Key SLO dashboards track: deletion success rate (target: >99.99%), end-to-end latency p99, HSM operation queue depth, Kafka consumer lag, and audit event ingest rate. PagerDuty integration routes critical alerts — including any DEK destruction failure — to the on-call security engineer with a response SLA of 15 minutes.

15. Budget and Resource Summary

15.1 Project Budget

Budget Category	Budgeted ($)	Actual ($)	Variance
Engineering Labour (14 weeks, 6 engineers)	252,000	248,400	-$3,600
Security Architecture & Consulting	45,000	47,200	+$2,200
HSM Hardware (2x Thales Luna 7)	68,000	68,000	$0
Independent Penetration Test (NCC Group)	35,000	32,500	-$2,500
Cloud Sandbox Infrastructure	12,000	10,800	-$1,200
Legal Review (Morrison Foerster LLP)	18,000	19,500	+$1,500
QA Tools and Licences	8,000	7,600	-$400
Contingency (10%)	43,800	0	-$43,800
Total	**481,800**	**434,000**	**-$47,800 (9.9%)**

The project was delivered under budget by $47,800 (9.9%), primarily due to efficient sprint execution that rendered the contingency reserve unnecessary and reduced cloud infrastructure costs through early adoption of spot instance pricing.

15.2 Team Composition

Role	Responsibilities	Allocation
Lead Security Architect	Architecture design, threat modelling, security gate reviews.	Full-time, all phases
Go Backend Engineer (x2)	Gateway Service, cloud adapters, performance optimisation.	Full-time, Phases 1–4
Java Engineer	HSM Key Manager, PKCS#11 integration, key lifecycle.	Full-time, Phases 1–4
Full-Stack Engineer	Admin Console, REST API, SIEM connectors.	Full-time, Phases 3–4
DevSecOps Engineer	CI/CD, Kubernetes, Terraform, observability.	Full-time, all phases
QA Engineer	Test strategy, integration tests, performance tests.	Full-time, Phases 2–4
Compliance Analyst (part-time)	Regulatory mapping, documentation, legal liaison.	50%, all phases

16. Lessons Learned and Recommendations

16.1 What Went Well

- Early HSM procurement (initiated in Week 1) eliminated a major supply-chain risk that would have blocked Phase 2.
- Using LocalStack and Testcontainers for local integration testing dramatically reduced cloud infrastructure costs during development.
- Threat modelling in Phase 0 identified the two-phase commit requirement for DEK destruction before any code was written, saving significant rework.
- The modular adapter pattern for cloud providers proved its value when Azure Blob Storage updated its authentication API mid-project, requiring changes only to the Azure adapter module.
- Embedding a compliance analyst from Day 1 ensured that regulatory requirements were baked into design decisions rather than retrofitted.

16.2 Challenges Encountered

- PKCS#11 HSM SDK documentation was inconsistent across firmware versions, requiring direct engagement with Thales support engineers during Week 5.
- Go's standard library AES-GCM implementation does not natively support streaming for large files; a custom chunked streaming cipher was implemented, which required additional security review.
- Kafka consumer group rebalancing during rolling deployments caused brief audit log ingestion gaps; resolved by implementing a sticky partition assignment strategy.
- The Admin Console accessibility review (WCAG 2.1 AA) identified 14 issues that were not caught by automated tooling, requiring a dedicated remediation sprint.

16.3 Recommendations for Future Phases

- Extend DFET to on-premises NAS/SAN environments using a hardware-based encryption offload appliance to provide consistent erasure guarantees across hybrid storage estates.
- Implement client-side encryption within the SDK/agent layer to provide end-to-end encryption where the cloud provider never receives plaintext, further reducing trust surface area.
- Introduce automated compliance drift detection that continuously monitors DFET configuration against the approved security baseline and alerts on deviation.
- Evaluate post-quantum cryptographic primitives (NIST FIPS 203 ML-KEM, FIPS 204 ML-DSA) for key encapsulation and signatures to future-proof against quantum adversaries.
- Develop a self-service onboarding portal for enterprise tenants to reduce operational burden on the platform team during client provisioning.
- Establish a formal bug bounty programme with a defined scope covering the DFET Admin Console and REST API to leverage community security research.

17. Conclusion

The Deleted File Encryption Tool for Cloud Storage project has successfully delivered a production-grade cryptographic erasure solution that addresses a critical and previously unmitigated gap in enterprise cloud data lifecycle security. By combining per-file AES-256-GCM encryption with FIPS 140-2 Level 3 HSM-backed key management and atomic key destruction, DFET provides provable, auditable, and legally defensible data erasure for all three major cloud storage platforms.

The solution was delivered on schedule, 9.9% under budget, and received a clean penetration test report from an independent third party. Pilot deployment across three enterprise clients processed 2.4 million files with a deletion latency consistently below the 100 ms SLA target, and achieved a compliance readiness score of 98.6 out of 100 against the applicable regulatory framework.

The project has established SecureVault Technologies Inc. as a technical leader in cloud data erasure and positions the organisation to serve clients in highly regulated industries—financial services, healthcare, and government—where data minimisation and right-to-erasure obligations are becoming increasingly stringent and enforcement activity is intensifying globally.

> **Strategic Value**
> DFET transforms 'we deleted it' from an unverifiable assertion into a cryptographically provable, HSM-attested, and audit-logged fact. This capability is increasingly required by regulators and enterprise procurement teams, and represents a sustainable competitive differentiator.

The project team recommends proceeding to full General Availability release following completion of SOC 2 Type II audit evidence collection, planned for Q3 2025. Simultaneously, the roadmap items identified in Section 16 — specifically on-premises extension, client-side encryption, and post-quantum cryptography readiness — should be scoped into the next investment cycle to maintain technological leadership.

Document Control

Author	Reviewer	Approver	Date
Cloud Security Eng.	CISO Office	CTO	April 2025